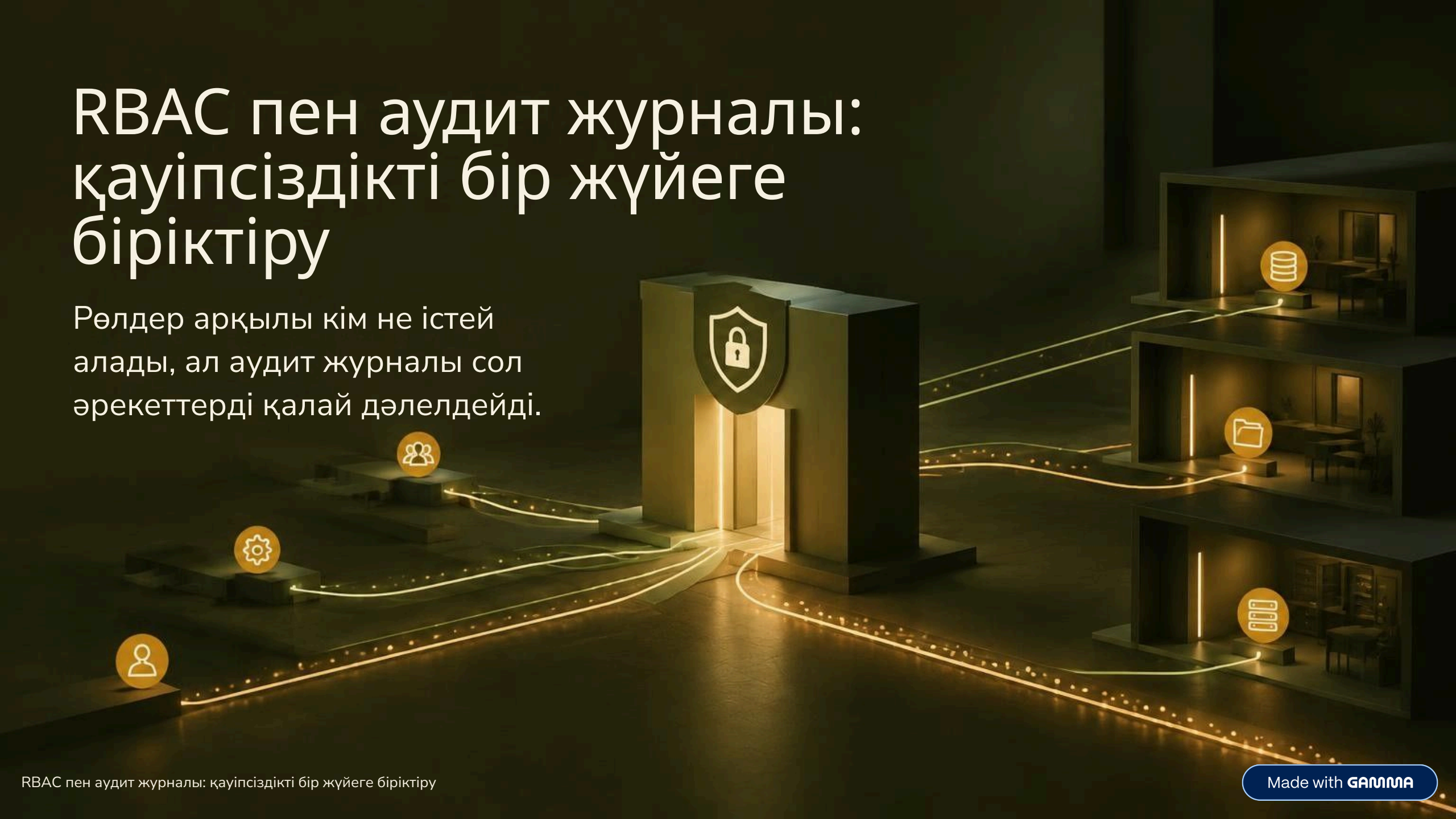
RBAC пен аудит журналы: қауіпсіздікті бір жүйеге біріктіру

Рөлдер арқылы кім не істей алады, ал аудит журналы сол әрекеттерді қалай дәлелдейді.



Made with GAMMA

01 — МӘСЕЛЕ

Рұқсат бар, бірақ бақылау жоқ

Қауіпсіздік тек кіруге рұқсат берумен аяқталмайды.



Шашыраңқы рұқсаттар

Рұқсаттар жүйеге шашыраса, артық қолжетімділік көбейеді.



Көрінбейтін әрекет

Әрекет тіркелмесе, инциденттің қайдан басталғанын анықтау қиындайды.



Толық басқару

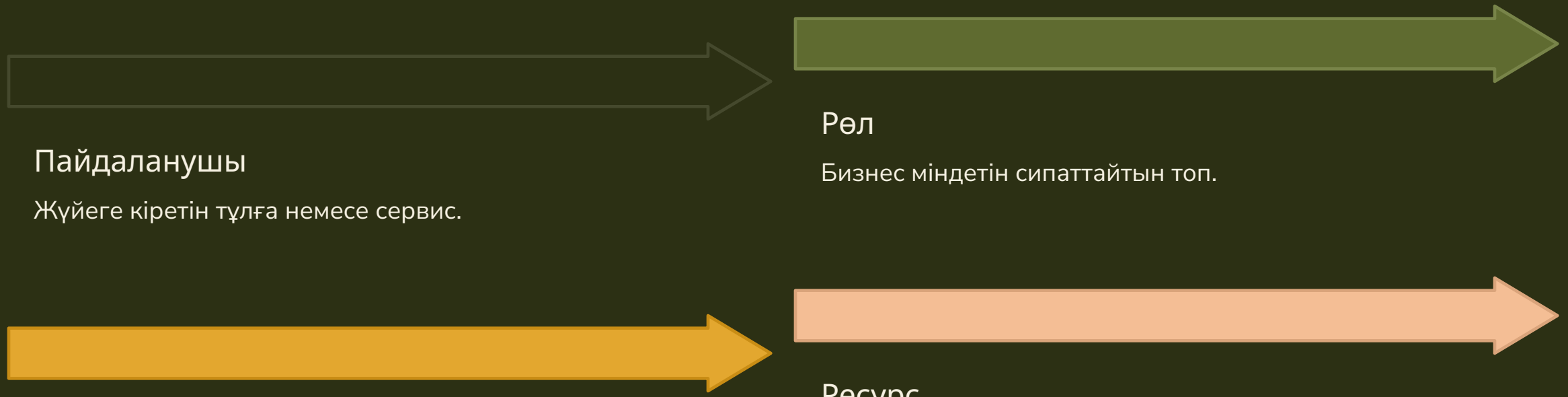
RBAC пен аудит бірге жұмыс істегенде ғана басқару толық көрінеді.

Made with GAMMA

02 — МОДЕЛЬ

RBAC моделі төрт негізгі нысанға сүйенеді

Әр нысанның рөлі бөлек, ал байланыс олардың қалай жұмыс істейтінін көрсетеді.



Пайдаланушы

Жүйеге кіретін тұлға немесе сервис.

Рөл

Бизнес міндетін сипаттайтын топ.

Рұқсат

Нақты ресурс пен әрекет жұбы.

Ресурс

Қол жеткізілетін нысан.

Пайдаланушы → Рөл → Рұқсат → Ресурс

Made with GAMMA

03 — ҚҰРАЛ

Кітапхана рұқсаттарды кодтан бөлек басқаруға көмектеседі

Тексеру логикасы бір жерде тұрса, саясатты өзгерту де, бақылау да жеңілдейді.

Модельдеңіз

Рөлдер мен рұқсаттарды орталық модельге жинаңыз.

Тексеріңіз

Middleware немесе guard арқылы сұрауды тексеріңіз.

Жауап беріңіз

Саясат орындалмаса, стандартты қате қайтарыңыз.

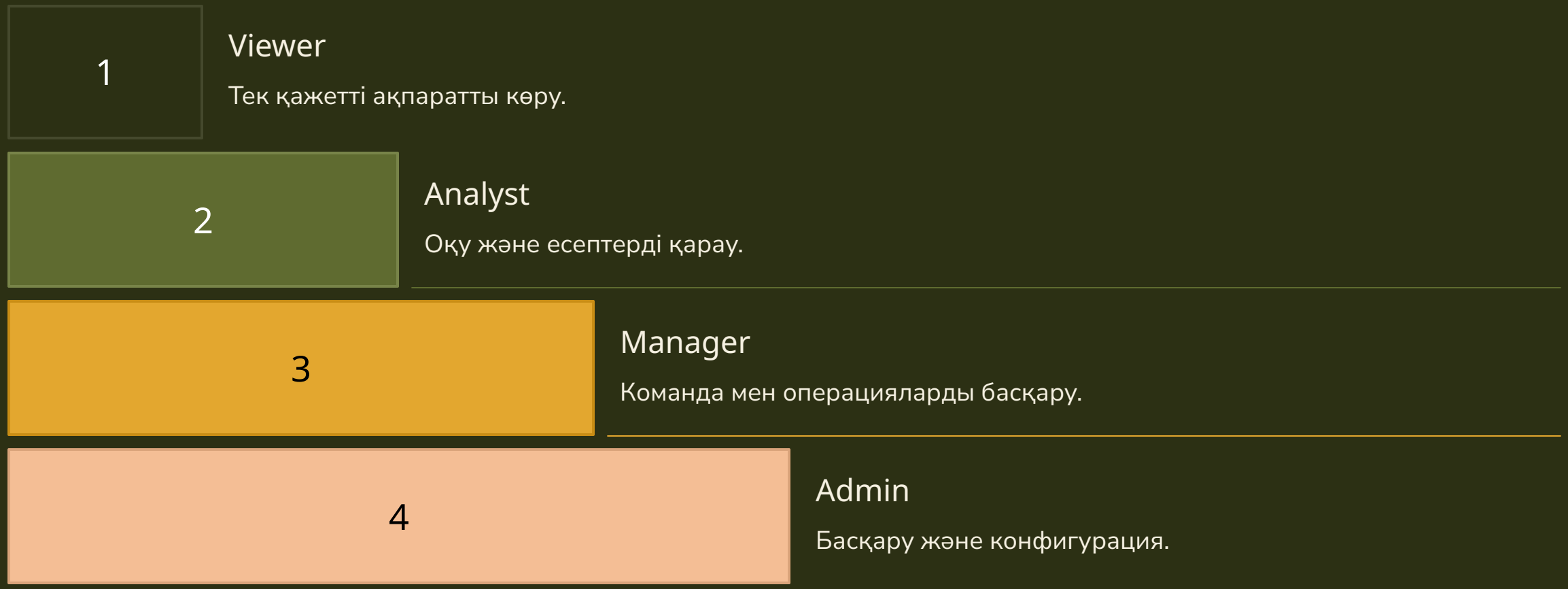
Тіркеңіз

Тексеру нәтижесін аудит оқиғасына айналдырыңыз.

Made with GAMMA

Рөлдер иерархиясы қарапайым әрі түсінікті болуы керек

Ең аз қажетті құқық қағидасы әдепкі шешім болсын.



Made with GAMMA

05 — АУДИТ

«Кім, қашан, не істеді?»

Аудит журналы осы сұраққа дәлелді жауап береді.

Өріс	Мақсаты
actor	Әрекетті бастаған субъект
action	Орындалған операция
target	Әсер еткен ресурс
result	Рұқсат берілді ме, қабылданбады ма

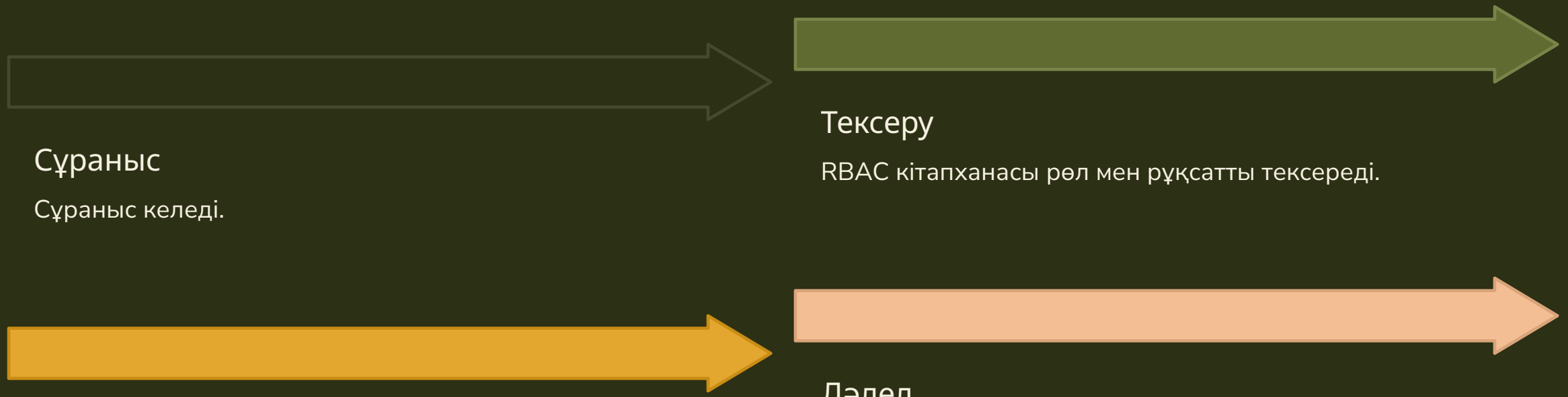
Контекстке уақыт, IP және сұрау идентификаторы қосылады.

Made with GAMMA

06 — БАЙЛАНЫС

RBAC шешімі аудит оқиғасына айналуы тиіс

Осы байланыс қауіпсіздік саясатын тексерілетін ізге айналдырады.



Сұраныс

Сұраныс келеді.

Тексеру

RBAC кітапханасы рөл мен рұқсатты тексереді.

Шешім

Нәтиже: allow немесе deny.

Дәлел

Журнал шешімді, контексті және нәтижені сақтайды.

Made with GAMMA

07 — САПА

Журналдың сапасы сақтаудан бұрын басталады

Жақсы журнал кейін іздеуге ғана емес, дұрыс оқуға да дайындалады.

Бірізді атау

Оқиға атаулары бірізді болсын: resource.action.

Дерек гигиенасы

Сезімтал деректерді журналға жазбаңыз.

Қорғалған сақтау

Өзгертуге қарсы қорғаныс пен сақтау мерзімін анықтаңыз.

Қолдану сценарийі

Іздеу, сүзу және экспортты алдын ала тексеріңіз.

Made with GAMMA

08 — ІСКЕ АСЫРУ

Іске асырудың қысқа жолы

Алдымен шекараны анықтаңыз, кейін тексеруді және бақылауды бір арнаға жинаңыз.

Ресурстар

Ресурстар мен бизнес әрекеттерінің тізімін жасаңыз.

Рөлдер

Рөлдерді ең аз құқық қағидасымен жобалаңыз.

Бір кітапхана

Рұқсат тексеруін бір кітапханаға шоғырландырыңыз.

Екі нәтиже

Allow және deny шешімдерінің екеуін де тіркеңіз.

Бақылау панелі

Күнделікті тексеру үшін бақылау панелін құрыңыз.

Made with GAMMA

09 — НӘТИЖЕ

Рұқсат басқарылатын, әрекет дәлелденетін жүйе

RBAC

Кімнің не істей алатынын анықтайды.

Аудит журналы

Нақты не болғанын көрсетеді.

Бірге

Инцидентті тергеуге, сәйкестікті дәлелдеуге және тәуекелді азайтуға негіз болады.

Made with GAMMA